CloudDesk Technologies

Encryption and Key Management Policy

1. Purpose, scope and document authority

Document control

Policy ID: CD-ENC-001 | Version: 1.0 | Effective date: 2026-10-22 (fictional). Owner: Engineering Lead. Accountable approver: CTO (fictional role; approval not recorded). Review cycle: annually and after material architecture or cryptographic changes; next scheduled review: 2027-10-22. Classification: SYNTHETIC / DEMO.

Status and limits

CloudDesk Technologies is a fictional 75-person B2B SaaS company. Every control below is an assumed demo requirement, not a verified implementation fact. This model-authored document requires user review; it is not human-approved evidence. No certification, external audit, legal compliance conclusion or actual operating effectiveness is claimed.

Scope

This policy applies to employees, contractors and service identities handling customer data, credentials, production configuration or internal confidential information in the hosted SaaS service, supporting cloud infrastructure, corporate endpoints and backups. Public marketing content may be stored unencrypted; authentication and administrative traffic remain subject to transport protection. Vendors handling scoped information must be assessed against these requirements before use.

Related access requirements

Use unique user accounts. Multi-factor authentication is required for administrative access. User access permissions are reviewed every quarter. Terminated employee access is revoked within 24 hours. These requirements preserve the existing access-control sample; key authorization below adds restrictions without replacing them. Customer-managed keys and end-to-end encryption are not assumed capabilities.

Encryption and Key Management Policy

2. Encryption in transit and at rest

Transport protection

Require TLS 1.2 or TLS 1.3 for customer sessions, APIs, administrative consoles and service connections carrying scoped information, including database connections and internal service traffic. Disable SSL and TLS versions below 1.2 and plaintext fallbacks. Redirect public HTTP entry traffic to HTTPS without accepting credentials or confidential request bodies over HTTP.

Certificates and validation

Validate certificate trust, hostname and expiry on clients; do not bypass verification. Platform Engineering maintains a certificate inventory with ownership and expiry alerts at least 30 days before expiration. Renew certificates before expiry and replace compromised certificate private keys immediately under incident response. Prefer managed certificate issuance and renewal.

Stored information

Use AES-256 encryption at rest through managed cloud encryption for production databases, object storage, persistent volumes, snapshots and scoped log archives. Require full-disk encryption on company laptops using the supported operating system encryption facility. Do not persist scoped information on unencrypted removable media. Engineering verifies encryption settings before provisioning production storage.

Application boundaries

Encryption at rest protects stored media; authorized application processes can still read plaintext. Do not place credentials or private key material in source code, application logs or support exports. Store service credentials in the approved secrets manager. Passwords must be salted and hashed with a purpose-built password hashing scheme rather than reversibly encrypted. Do not implement custom cryptographic algorithms.

Encryption and Key Management Policy

3. Key storage, access and lifecycle

Key storage

Platform Engineering uses a managed cloud key management service (KMS) for production encryption keys and envelope encryption. Key-encryption keys remain non-exportable in KMS; store encrypted data keys with their encrypted objects when required by the service. Use a secrets manager for application secrets and supported certificate private keys. Separate production keys and grants from development and test.

Key access

Grant decrypt operations only to named workload identities and approved operators with a documented business need. Use least privilege and separate key administration from routine data access; key administrators receive no default decrypt permission. The Engineering Lead approves grants. Human administrative access uses unique accounts and MFA. Review key grants every quarter and revoke terminated employee access within 24 hours.

Rotation

Rotate symmetric key-encryption keys at least every 12 months using managed rotation where supported. Rotation creates a new active version; new encryption uses that version. Retain restricted decrypt access to older versions only for data or backups still within retention. Rotation alone does not re-encrypt historical data. Platform Engineering records rotation date, version and outcome in the key inventory.

Compromise, revocation and destruction

On suspected key compromise, immediately open an incident, revoke affected identity grants and disable compromised key versions where safe. Provision replacement keys and assess re-encryption, affected data and backup recoverability. CTO authorizes any temporary emergency decrypt access with logging and next-business-day review. Destroy retired versions only after dependent data retention ends and recovery checks show no remaining need; require Engineering Lead and CTO approval and record destruction evidence.

Encryption and Key Management Policy

4. Backups, exceptions and assurance

Backup encryption and recovery

Encrypt all production backups and snapshots at rest with AES-256 and protect backup transfers with TLS 1.2 or TLS 1.3. Use backup-specific key grants separate from ordinary application access. Retain necessary older key versions for the full lifetime of retained backups, including legal or incident holds if applicable. Test a representative encrypted restore at least quarterly, recording data integrity, authorized key access and recovery outcome. Backup schedules and retention periods are outside this policy and are not asserted here.

Exceptions

Before deviation, the system owner submits a ticket recording affected data, reason, risk, compensating controls, owner and expiry date. Engineering Lead assesses the request and CTO approves or rejects it. Approvals expire within 90 days; review monthly and close with remediation evidence. Renewal requires a fresh assessment and approval. Emergency deviations require an incident record and CTO review by the next business day. This sample asserts no active exceptions.

Responsibilities

CTO is accountable for risk acceptance and destructive key actions. Engineering Lead owns this policy and approves key grants. Platform Engineering implements encryption, certificate monitoring, rotation and restore checks. System owners maintain their inventories and remediate deviations. All personnel report suspected exposure promptly through the incident process; application teams avoid logging plaintext secrets.

Evidence and review references

Expected internal evidence types: storage encryption configuration exports; TLS configuration and certificate inventory; KMS key inventory, grant approvals and quarterly access reviews; rotation and destruction records; encrypted restore reports; exception tickets and incident records. Review KMS administrative and decrypt audit events monthly and after incidents; retain those audit logs for at least 12 months in access-restricted encrypted storage. These are proposed demo evidence references, not existing audit artifacts or test results. Review policy annually and after material changes; record revisions and approvals before treating it as an approved policy.